

ТЕХНИЧЕСКИ УНИВЕРСИТЕТ – СОФИЯ

**ФАКУЛТЕТ „КОМПЮТЪРНИ СИСТЕМИ И
ТЕХНОЛОГИИ“**



**СИСТЕМА ЗА АНАЛИЗ НА ТРАНСПОРТНАТА
СИГУРНОСТ И ЗА УПРАВЛЕНИЕ НА
ДОПУСКАНЕТО НА ВРЪЗКИ ПРИ УСЛОВИЯ
НА ЛАВИНЕН ТРАФИК**

КУРСОВ ПРОЕКТ

по дисциплина „Мрежова и информационна сигурност“

Разработил:

Алекс Цветанов, фак. № **[TODO: фак. номер]**

Специалност: Компютърно и софтуерно инженерство, ОКС „Магистър“

Преподавател:

Проф. д-р инж. Румен Трифонов

София, **[TODO: година на предаване]**

СЪДЪРЖАНИЕ

УВОД	1
I. АНАЛИЗ НА ПРЕДМЕТНАТА ОБЛАСТ И ЛИТЕРАТУРЕН ПРЕГЛЕД	3
1.1. Стандарти и политики	3
1.2. Заплахи и тяхната класификация	3
1.3. Протоколни спецификации	4
II. АНАЛИЗ НА ВЪЗМОЖНИТЕ РЕШЕНИЯ И ОБОСНОВКА НА ИЗБОРА	6
2.1. Източник на данните за анализа	6
2.2. Обхват на собствената реализация	6
2.3. Стратегия за допускане на връзки	7
2.4. Език и инструментариум	7
III. ПРОЕКТИРАНЕ НА СИСТЕМАТА	8
3.1. Слой за придобиване и разчитане	8
3.2. Слой за проверка на сертификатната верига	8
3.3. Слой за допускане на връзки	9
3.4. Модел на заплахата и граници на системата	9
IV. ПРОГРАМНА РЕАЛИЗАЦИЯ	10
4.1. Обща структура на изходния текст	10
4.2. Разчитане на ръкостискането	10
4.3. Проверка на веригата	10
4.4. Механизми за допускане	11
V. МЕТОДИКА ЗА ЕКСПЕРИМЕНТАЛНА ПРОВЕРКА	12
5.1. Среда за провеждане	12
5.2. Набори от данни	12
5.3. План на измерванията при лавинен трафик	12
5.4. Изисквания за валидност	13
5.5. Очаквани резултати	13
VI. ЕКСПЕРИМЕНТАЛНИ РЕЗУЛТАТИ И АНАЛИЗ	14

6.1. Разчитане на ръкостискането	14
6.2. Проверка на сертификатните вериги	14
6.3. Цена на механизмите за допускане	14
6.4. Отчитане на предварителните очаквания	15
ЗАКЛЮЧЕНИЕ	16
ЛИТЕРАТУРА	17
ПРИЛОЖЕНИЯ	19

УВОД

Сигурността на един мрежов обмен днес се крепи на два механизма, които потребителят не вижда и обикновено не проверява. Първият е протоколът за защита на транспортния слой, който договаря шифрите и ключовия материал. Вторият е инфраструктурата на публичните ключове, която свързва един публичен ключ с едно име и позволява тази връзка да бъде отменена. И двата механизма са описани в публични спецификации, и двата се реализират от малък брой библиотеки, и точно затова техните свойства рядко се проверяват самостоятелно. Приема се, че щом връзката е установена, тя е защитена, а щом библиотеката не е върнала грешка, веригата от сертификати е валидна.

Настоящият курсов проект изхожда от обратната постановка. Договорените параметри на една връзка са наблюдаема величина и могат да бъдат прочетени от самия обмен. Валидността на една сертификатна верига е резултат от алгоритъм, който е записан в [1] и може да бъде реализиран самостоятелно, вместо да бъде приет наготово. Устойчивостта на един сървър срещу лавинен трафик е свойство, което се измерва, а не се декларира. Проектът разработва система, наречена Sentinel, която прави и трите неща: чете и разчита ръкостискането по TLS 1.3, проверява сертификатната верига по описания в стандарта алгоритъм за изграждане на път и за проверка на отмяната, и управлява допускането на нови връзки при условия на претоварване.

Целта на проекта е да се изгради работеща и измерима система за анализ на транспортната сигурност и за управление на допускането на връзки, чиито решения са проследими до конкретни изисквания на действащите стандарти, а цената на всеки защитен механизъм е измерена, а не предположена.

За постигането на целта са формулирани следните **задачи**:

1. преглед на действащите политики, стандарти и класификации на заплахите в мрежовата и информационната сигурност, с акцент върху публикациите на ISO, ITU, ETSI, ENISA и NIST;
2. анализ на възможните проектни решения по всяка от трите подзадачи и обосновка на направения избор;
3. проектиране на слоеста архитектура, в която разчитането на протокола, проверката на сертификатите и управлението на допускането са отделени един от друг;
4. програмна реализация на C++20, при която криптографските примитиви се вземат от

- утвърдена библиотека, а логиката на анализа и на проверката е собствена;
5. изграждане на методика за измерване на цената, която всеки механизъм за допускане внася в закъснението и в пропускателната способност;
 6. експериментална проверка в собствена изолирана среда и анализ на получените резултати.

Обхватът на проекта е защитен. Системата анализира, проверява и допуска. Тя не съдържа средства за проникване, за заобикаляне на защити или за атака срещу чужда инфраструктура. Всички опити с лавинен трафик се провеждат единствено срещу собствения стенд на проекта, изграден върху локален интерфейс и контейнери, и това ограничение е част от методиката, а не пожелание към нея.

Структура на изложението. Раздел I разглежда предметната област, стандартите и класификацията на заплахите. Раздел II излага разгледаните алтернативи и обосновава избора между тях. Раздел III представя проектирането на системата, а Раздел IV нейната програмна реализация. Раздел V описва методиката на експериментите, а Раздел VI получените резултати и техния анализ. Заключението обобщава предимствата и недостатъците на решението и очертава посоките за по-нататъшна работа.

I. АНАЛИЗ НА ПРЕДМЕТНАТА ОБЛАСТ И ЛИТЕРАТУРЕН ПРЕГЛЕД

Мрежовата и информационната сигурност е област, в която нормативните документи изпреварват реализациите. Преди да се проектира каквато и да е система, е нужно да се установи срещу какво се защитава тя и кой документ определя дали защитата е достатъчна. Този раздел прави този преглед в три стъпки: първо стандартите и политиките, после класификацията на заплахите, накрая конкретните протоколни спецификации, върху които стъпва реализацията.

1.1. Стандарти и политики

Рамката за управление на информационната сигурност се задава от серията ISO/IEC 27000. За настоящата задача пряко приложима е ISO/IEC 27033-1 [2], която въвежда понятията за мрежова сигурност, разделя мрежата на зони и описва как се избират защитни мерки за границата между тях. Архитектурният речник, върху който стъпват тези документи, идва от препоръките на ITU-T. Форматът на сертификата за публичен ключ, върху който се крепи цялата проверка в Раздел III, е дефиниран в препоръката ITU-T X.509 [3], а профилът му за приложение в интернет е зададен от IETF в [1].

От страна на техническите указания NIST издава документи, които се четат като изисквания към конфигурация, а не като теория. За избора и настройката на реализациите на TLS това е [4], а за защитните стени и политиката им [5]. Двата документа са особено полезни за настоящия проект, защото формулират проверими твърдения. Изискване от вида „да не се договаря версия под TLS 1.2“ е нещо, което анализаторът на ръкостискането може да провери автоматично.

Публикациите на ETSI, които попадат в обхвата на дисциплината, засягат преди всичко доставчиците на удостоверителни услуги и изискванията към тях. Конкретните документи, които влизат в този преглед, се определят и цитират в **[TODO: конкретни публикации на ETSI, сверени по номер и версия]**.

1.2. Заплахи и тяхната класификация

Годишният доклад на ENISA [6] подрежда наблюдаваните заплахи по категории и проследява как относителната им тежест се променя. За настоящия проект значение

имат три от тях. Първата е отказът на услуга, включително разпределеният му вариант, при който източниците на трафик са множество компрометирани машини. Втората е злоупотребата с инфраструктурата на публичните ключове, при която проверяващата страна приема сертификат, който не би трябвало да приеме. Третата е манипулацията на разрешаването на имена, при която жертвата получава правилен по форма отговор, но с подменено съдържание.

Защитата на уеб приложенията стои встрани от трите, но е част от учебното съдържание и е неотделима от транспортния слой. Класификацията на OWASP [7] подрежда рисковете при уеб приложенията и е използвана тук като контролен списък при определянето какво остава извън обхвата на проекта. Проектът не се занимава с логиката на приложението, а със слоя под него.

За защитата на разрешаването на имена изходната точка е [8], който въвежда изискванията към DNSSEC и обяснява защо липсата на удостоверяване на произхода на отговора е структурен, а не реализационен проблем. Отношението между тази защита и настоящата система е косвено, но съществено: ако името е разрешено до грешен адрес, проверката на сертификатната верига остава единственият механизъм, който може да открие подмяната.

1.3. Протоколни спецификации

Основната спецификация за анализатора е [9]. TLS 1.3 се различава от предходните версии по това, че съкращава ръкостискането и шифрира по-голямата част от него, което пряко определя докъде може да стигне пасивният анализ. Наблюдаемата част от обмена и границата, отвъд която анализаторът вижда само шифриран текст, се уточняват в Раздел III.

Механизмите за защита срещу лавина от заявки за установяване на връзка са описани в [10]. Документът разглежда систематично защо лавината от SYN сегменти е евтина за източника и скъпа за получателя, и излага контрамерките, включително подхода с криптографски изчислени начални последователни номера. Този документ е основата на Раздел V, защото описва не само мерките, но и техните странични ефекти, а именно те се измерват в настоящия проект.

Накрая, [11] описва как QUIC въвежда ключовата обмяна на TLS 1.3 в собствен транспортен слой. Спецификацията е включена в прегледа, защото показва, че

разглежданите тук механизми не са свързани с конкретен транспорт, и защото поставя въпроса дали анализаторът може да бъде разширен и към този случай.

II. АНАЛИЗ НА ВЪЗМОЖНИТЕ РЕШЕНИЯ И ОБОСНОВКА НА ИЗБОРА

Всяка от трите подзадачи допуска повече от едно решение и изборът между тях предопределя както обхвата, така и това, което изобщо може да бъде измерено. Разделът излага разгледаните възможности и мотивите за приетото решение.

2.1. Източник на данните за анализа

Първата възможност е анализът да се извършва вътре в приложението, чрез обратни извиквания на криптографската библиотека, която вече е разчела съобщенията. Реализацията тогава е кратка, но резултатът описва само собствените връзки на приложението и е обвързан с версията на библиотеката.

Втората възможност е пасивно наблюдение на трафика чрез librsar, върху жив интерфейс или върху записан файл в PCAP формат. Тук разчитането на съобщенията е задача на проекта, което е повече работа, но дава две предимства. Анализът обхваща чужди на приложението връзки, а записаният файл прави всяко измерване възпроизводимо, защото входът е фиксиран.

Приема се втората възможност. Основанието е методологично: работата с фиксиран запис превръща анализатора в детерминиран инструмент, а без това резултатите от Раздел VI не биха били възпроизводими.

2.2. Обхват на собствената реализация

Криптографските примитиви са зона, в която собствената реализация е грешка. Изборът на алгоритми, устойчивостта им спрямо атаки по странични канали и правилността на самите изчисления са резултат от години рецензии. Затова примитивите се вземат от утвърдена библиотека.

Логиката над примитивите обаче е предмет на проекта. Разчитането на съобщенията на ръкостискането, изграждането на пътя до доверен корен, проверката на ограниченията върху името и на разширенията, както и обработката на състоянието на отмяната, се реализират самостоятелно по описанието в [1] и [12]. Разделянето е съзнателно: то оставя примитивите на този, който ги е доказал, а проверимата логика на този, който я изучава.

2.3. Стратегия за допускане на връзки

Разгледани са четири механизма за защита при лавинен трафик, всеки от които има различна цена. Криптографски изчислените начални последователни номера, описани в [10], премахват нуждата от състояние за незавършена връзка, но ограничават кои опции могат да се договорят. Ограничаването на честотата по източник е евтино, но е безполезно срещу разпределен източник. Допускането срещу изчислителна задача прехвърля цената върху клиента, но внася закъснение при всяко първо свързване. Отчитането на таблицата с връзките е по-скоро измерителен, отколкото защитен механизъм, но без него останалите три не могат да бъдат оценени.

Приема се всичките четири да бъдат реализирани и включвани поотделно, вместо да се избере един. Причината е, че въпросът на проекта не е кой механизъм е най-добър, а колко струва всеки от тях. Отговорът на този въпрос изисква сравнение при еднакви условия, тоест изисква всички да съществуват в една и съща система.

2.4. Език и инструментариум

Изборът на C++20 е продиктуван от три съображения. Разчитането на протокола работи с байтови буфери, за което `std::span` дава невладеещ изглед без копиране и без загуба на дължината. Измерването на закъснението изисква предвидимо време на изпълнение, без паузи от събиране на боклука. И накрая, `librsap` и утвърдените криптографски библиотеки предлагат интерфейс на C, който се използва пряко.

Алтернативите бяха разгледани и отхвърлени: Rust заради по-малкия личен опит на автора в рамките на срока на проекта, а езиците със среда за изпълнение и събиране на боклука заради влиянието им върху точно тази величина, която проектът измерва.

III. ПРОЕКТИРАНЕ НА СИСТЕМАТА

Системата е разделена на четири слоя, така че всеки от тях да може да бъде проверен самостоятелно. Слойът за придобиване на данни доставя байтове, независимо дали са от жив интерфейс или от записан файл. Слойът за разчитане превръща байтовете в структури на протокола. Слойът за проверка взема решение за валидността на сертификатната верига. Слойът за допускане решава дали една нова връзка да бъде обслужена. Общата схема на слоевете и потокът от данни между тях се дават на **[TODO: фигура с блоковата схема на системата, с легенда по A.9]**.

3.1. Слой за придобиване и разчитане

Придобиването е скрито зад един интерфейс с два реализатора: единият чете от жив интерфейс през `librsap`, другият от записан файл. Тестовите използват втория, защото той е детерминиран.

Разчитането следва структурата на записите и на съобщенията от [9]. Съществено проектно решение тук е границата на видимостта. В TLS 1.3 само първата част от ръкостискането е в явен вид, а останалата е шифрована с ключове, които пасивният наблюдател няма. Затова анализаторът докладва това, което наистина се наблюдава, и обозначава изрично като неизвестно всичко останало, вместо да го извежда по подразбиране. Пълният списък на наблюдаемите и на скритите параметри се дава в **[TODO: таблица с наблюдаеми и скрити параметри на ръкостискането]**.

Разчитането работи изцяло върху невладеещи изгледи към получения буфер. Нито една структура не притежава байтовете, които описва. Това премахва копирането по пътя на анализа и същевременно поставя ясно изискване към времето на живот на буфера, което се проверява от тестовите.

3.2. Слой за проверка на сертификатната верига

Проверката се извършва на два етапа. Първият изгражда пътя от сертификата на края до доверен корен, като разглежда всички възможни продължения, а не само първото намерено. Вторият проверява за всеки сертификат по пътя ограниченията, изисквани от [1]: срок на валидност, подпис на издателя, основни ограничения, предназначение на ключа, ограничения върху имената и съответствие на името на края.

Проверката на отмяната е отделена от проверката на пътя, защото има различна цена и различен режим на отказ. Поддържат се два източника: списък на отменените сертификати и протоколът за състояние по [12]. Политиката при недостъпен източник е проектно решение с последици за сигурността и се задава явно, а не се подразбира. Разгледаните варианти и приетият се описват в **[TODO: вариантите на политиката при недостъпен източник на информация за отмяна]**.

3.3. Слой за допускане на връзки

Слоят за допускане стои пред сървъра и решава дали да отдели ресурс за нова връзка. Проектиран е като верига от независими механизми, всеки от които може да бъде включен или изключен, без това да засегне останалите. Такава организация е необходима, защото измерването в Раздел V изисква всеки механизъм да бъде оценен и поотделно, и в съчетание с другите.

Отчитането на таблицата с връзките е общо за цялата верига. То поддържа броя на незавършените и на установените връзки, разпределението им по източници и времето, прекарано във всяко състояние. Тези величини са едновременно вход за решенията и изход за измерването.

3.4. Модел на заплахата и граници на системата

Системата приема, че наблюдателят няма достъп до частните ключове и не може да дешифрира защитената част от обмена. Приема също, че опитите с лавинен трафик се провеждат в среда, която е изцяло под контрола на автора. Извън модела на заплахата остават атаките срещу самата машина, върху която работи системата, както и атаките срещу приложния слой над транспорта. Пълното изложение на модела и на приетите допускания се дава в **[TODO: таблица с модела на заплахата: актьор, способност, мярка]**.

IV. ПРОГРАМНА РЕАЛИЗАЦИЯ

Реализацията е на C++20 и се изгражда с CMake. Проектът е разделен на библиотека, която съдържа цялата логика, и на изпълними файлове, които са тънки обвивки над нея. Разделянето е направено заради тестовете: всичко, което заслужава проверка, живее в библиотеката и се вика пряко от тестовете, без да се минава през команден ред.

4.1. Обща структура на изходния текст

Публичните заглавни файлове стоят в `include/`, реализацията в `src/`, тестовете в `tests/`. Всеки от четирите слоя от Раздел III е отделен превод и отделна цел за компилация, така че зависимостите между слоевете да са видими в конфигурацията, а не само в текста. Пълната йерархия на модулите и списъкът на класовете се дават в **[TODO: таблица с модулите, целите за компилация и зависимостите между тях]**.

4.2. Разчитане на ръкостискането

Разчитането е реализирано като поредица от функции, всяка от които приема изглед към байтове и връща или разчетената структура, или причина за отказа. Няма изключения по пътя на разчитането. Причината е, че повреденият или нарочно изкривен вход е нормално явление за този слой, а не изключителна ситуация, и обработката му трябва да е еднакво евтина при всеки пакет.

Всяка стъпка проверява дължината преди четенето. Това е основното изискване към слоя, който работи с чужд вход, и е предмет на отделен набор от тестове с нарочно подготвени неправилни съобщения. Резултатите от тези тестове се описват в **[TODO: резултати от проверката с неправилни и съкратени съобщения]**.

4.3. Проверка на веригата

Изграждането на пътя е реализирано с обхождане в дълбочина по множеството от кандидат-издатели, с ограничение върху дължината на пътя и с отчитане на вече посетените, за да не се получи безкраен цикъл при кръстосано подписани сертификати. Всяко отхвърляне на кандидат се записва с причина, така че при неуспех системата да може да обясни защо нито един път не е бил приет, вместо просто да върне отказ.

Криптографските проверки на подписа се възлагат на външната библиотека. Всичко останало, включително проверката на ограниченията върху имената, е собствена реализация по [1]. Конкретната библиотека и нейната версия се посочват в **[TODO: криптографска библиотека и версия, използвани в окончателната реализация]**.

4.4. Механизми за допускане

Четири механизма са реализирани зад общ интерфейс с едно решение: допускане или отказ, придружено с причина. Веригата се конфигурира при стартиране и не се променя по време на измерване, за да не се смесват режими в един и същ набор от данни.

Отчитането на таблицата с връзките използва структура, разделена по нишки, за да не се превърне самото измерване в тясно място. Приетият подход и мотивите за него се описват в **[TODO: избраната структура за отчитане и мотивите за нея]**. Избраните листинги от изходния текст се дават в Приложение 6.4.

V. МЕТОДИКА ЗА ЕКСПЕРИМЕНТАЛНА ПРОВЕРКА

Разделът описва как се получават резултатите от Раздел VI. Той се пише преди измерванията, а не след тях, за да може погрешно очакване да остане видимо и да бъде отчетено като погрешно.

5.1. Среда за провеждане

Всички опити се провеждат в изолирана среда, изградена изцяло от автора. Клиентът и сървърът работят върху локален интерфейс или в контейнери на една машина. Никакъв трафик не напуска тази среда и никаква външна услуга не участва в опитите. Това ограничение е задължително и не подлежи на облекчаване. Точната конфигурация на машината и на средата се описва в **[TODO: конфигурация на средата: процесор, памет, ядро, версии на инструментите]**.

5.2. Набори от данни

Анализаторът на ръкостискането се проверява върху записани файлове в PCAP формат, получени от собствената среда. Всеки запис се придружава от очаквания резултат, записан ръчно след разчитане на съответната спецификация. Проверката на веригата се провежда върху собствена йерархия от сертификати, изградена за целта, с нарочно въведени дефекти по един на сертификат: изтекъл срок, липсващо основно ограничение, несъответствие на името, отменен сертификат. Пълният списък на случаите се дава в **[TODO: таблица със случаите за проверка на веригата и очаквания резултат за всеки]**.

5.3. План на измерванията при лавинен трафик

Измерва се цената на всеки механизъм за допускане поотделно и на съчетанията им. За всяка конфигурация се снима закъснението при установяване на връзка, броят на успешно установените връзки за единица време и потребената памет за състояние. Всяка конфигурация се повтаря многократно, а докладваната стойност е медиана заедно с разсейването, а не единично измерване.

Измерва се и базова конфигурация, при която нито един механизъм не е включен. Без нея числата за останалите конфигурации нямат отправна точка. Броят на повторенията,

продължителността на един опит и загряващият период се определят предварително и се записват в **[TODO: параметри на опита: брой повторения, продължителност, загряване]**.

5.4. Изисквания за валидност

Измерването се приема за валидно само ако са изпълнени следните условия. Генераторът на натоварване не трябва да бъде тясното място, което се проверява с отделен опит срещу нищо неправещ приемник. Машината не трябва да е ограничена термично или от режима на управление на честотата. Разсейването между повторенията трябва да остане под предварително определен праг, иначе резултатът се отхвърля, а не се осреднява. Праговете се задават в **[TODO: числени прагове за приемане на измерването]**.

5.5. Очаквани резултати

Очакванията се записват тук преди измерването. Очаква се механизмът без съхранение на състояние да намали потребената памет при лавина за сметка на ограничение върху договаряните опции. Очаква се ограничаването по източник да има пренебрежимо закъснение и слаб ефект при разпределен източник. Очаква се допускането срещу изчислителна задача да внесе най-голямо закъснение при първо свързване. Дали тези очаквания се потвърждават, се отчита в Раздел VI, включително когато не се потвърждават.

VI. ЕКСПЕРИМЕНТАЛНИ РЕЗУЛТАТИ И АНАЛИЗ

Разделът представя получените резултати в реда на трите подзадачи и ги тълкува. Всяко число тук идва от измерване, проведено по методиката от Раздел V, и е придружено от условията, при които е получено.

6.1. Разчитане на ръкостискането

Резултатите от разчитането на записаните обмени се обобщават в (Табл. 1). За всеки запис се посочва броят на разчетените ръкостискания, броят на отхвърлените и причината за отхвърлянето.

Таблица 1. Резултати от разчитането на записаните обмени

Запис	Разчетени	Отхвърлени	Причина
[TODO:]	[TODO:]	[TODO:]	[TODO:]

Анализът на разминаванията между очаквания и получения резултат се прави в [TODO: анализ на случаите, при които разчитането се разминава с очакването].

6.2. Проверка на сертификатните вериги

Всеки случай за проверка от Раздел 5.2 има един очакван изход. Съпоставката между очаквания и получения изход се дава в (Табл. 2). Случай, при който системата приема верига, която трябва да отхвърли, се разглежда отделно и подробно, защото е дефект в сигурността, а не разминаване в числата.

Таблица 2. Съпоставка на очаквания и получения изход при проверката на вериги

Случай	Очакван изход	Получен изход	Съвпада
[TODO:]	[TODO:]	[TODO:]	[TODO:]

6.3. Цена на механизмите за допускане

Основният резултат на проекта е (Табл. 3): цената на всеки механизъм, измерена спрямо базовата конфигурация без включен механизъм. Формата на таблицата е определена в Раздел 5.3 преди измерването.

Таблица 3. Цена на механизмите за допускане спрямо базовата конфигурация

Конфигурация	Закъснение	Установени връзки	Памет за състояние
Без механизъм (база)	[TODO:]	[TODO:]	[TODO:]
Без съхранение на състояние	[TODO:]	[TODO:]	[TODO:]
Ограничаване по източник	[TODO:]	[TODO:]	[TODO:]
Изчислителна задача	[TODO:]	[TODO:]	[TODO:]
Всички включени	[TODO:]	[TODO:]	[TODO:]

Поведението на закъснението при нарастващо натоварване се представя графично в [TODO: фигура със закъснението като функция на натоварването, с легенда по A.9].

6.4. Отчитане на предварителните очаквания

Всяко очакване от Раздел 5.5 се отчита изрично като потвърдено или като неопровергано, заедно с измерването, което води до тази оценка. Отчитането се попълва в [TODO: отчитане на всяко предварително очакване спрямо измерените стойности]. Невярно очакване остава записано като невярно, а не се пренаписва.

ЗАКЛЮЧЕНИЕ

Проектът разработва система за анализ на транспортната сигурност и за управление на допускането на връзки, изградена от четири отделни слоя и проверена в изолирана собствена среда. Анализаторът разчита наблюдаемата част от ръкостискането по TLS 1.3 и отчита изрично докъде стига видимостта на пасивния наблюдател. Проверката на сертификатните вериги е реализирана самостоятелно по алгоритъма от [1], с изграждане на път и с отделена проверка на отмяната. Слой за допускане обединява четири механизма, всеки от които може да бъде включван поотделно, което позволява цената им да бъде измерена, а не предположена.

Предимства на решението. Разделянето на слоевете прави всеки от тях проверим самостоятелно. Работата върху записани обмени вместо върху жив трафик прави измерванията възпроизводими. Собствената реализация на логиката за проверка при взети наготово криптографски примитиви поставя границата там, където тя има смисъл: доказаното се използва, а изучаваното се пише. Обобщената оценка на постигнатото се дава в **[TODO: обобщена оценка след провеждане на измерванията]**.

Недостатъци и ограничения. Пасивният анализ на TLS 1.3 вижда само част от обмена и това е свойство на протокола, не на реализацията. Опитите с лавинен трафик се провеждат на една машина, което ограничава заключенията за поведението при разпределен източник. Измерените стойности важат за конкретната среда от Раздел 5.1 и не се пренасят автоматично. Пълният списък на установените ограничения се дава в **[TODO: списък на установените ограничения след провеждане на опитите]**.

Посоки за по-нататъшна работа. Първата посока е разширяване на анализатора към QUIC, където ключовата обмяна на TLS 1.3 се пренася в друг транспорт [11], а формата на съобщенията остава същата. Втората е измерване в среда с действително разпределен източник на трафик вместо на една машина. Третата е свързване на решенията за допускане с политиката на защитната стена по указанията в [5], така че решението да се прилага преди пакетът да достигне приложението.

ЛІТЕРАТУРА

- [1] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk, “Internet x.509 public key infrastructure certificate and certificate revocation list (crl) profile,” RFC 5280, Internet Engineering Task Force, May 2008.
- [2] International Organization for Standardization, Geneva, *ISO/IEC 27033-1:2015 Information technology – Security techniques – Network security – Part 1: Overview and concepts*, 2015.
- [3] International Telecommunication Union, Geneva, *Recommendation ITU-T X.509: Information technology – Open Systems Interconnection – The Directory: Public-key and attribute certificate frameworks*, October 2019.
- [4] K. McKay and D. Cooper, “Guidelines for the selection, configuration, and use of transport layer security (tls) implementations,” NIST Special Publication 800-52 Rev. 2, National Institute of Standards and Technology, August 2019.
- [5] K. Scarfone and P. Hoffman, “Guidelines on firewalls and firewall policy,” NIST Special Publication 800-41 Rev. 1, National Institute of Standards and Technology, September 2009.
- [6] European Union Agency for Cybersecurity (ENISA), “Enisa threat landscape 2023,” tech. rep., European Union Agency for Cybersecurity, October 2023.
- [7] OWASP Foundation, *OWASP Top 10:2021 – The Ten Most Critical Web Application Security Risks*, 2021.
- [8] R. Arends, R. Austein, M. Larson, D. Massey, and S. Rose, “Dns security introduction and requirements,” RFC 4033, Internet Engineering Task Force, March 2005.
- [9] E. Rescorla, “The transport layer security (tls) protocol version 1.3,” RFC 8446, Internet Engineering Task Force, August 2018.
- [10] W. Eddy, “Tcp syn flooding attacks and common mitigations,” RFC 4987, Internet Engineering Task Force, August 2007.
- [11] M. Thomson and S. Turner, “Using tls to secure quic,” RFC 9001, Internet Engineering Task Force, May 2021.

- [12] S. Santesson, M. Myers, R. Ankney, A. Malpani, S. Galperin, and C. Adams, “X.509 internet public key infrastructure online certificate status protocol – ocsp,” RFC 6960, Internet Engineering Task Force, June 2013.

ПРИЛОЖЕНИЯ

Приложение А. Изходен текст на избрани модули

Тук се включват листингите на модулите, върху които стъпват твърденията от Раздел IV. Листингите се вмъкват направо от файловете на проекта, за да останат свързани с действителния изходен текст, вместо да бъдат преписвани. Списъкът на включените модули се определя в **[TODO: списък на модулите, чийто изходен текст влиза в приложението]**.

Приложение Б. Формати на структурите от данни

Описание на структурите, с които работи слойът за разчитане, и на записа, използван за отчитане на връзките. Съдържанието се попълва в **[TODO: описание на структурите от данни и на записа за отчитане]**.

Приложение В. Конфигурация на средата за опити

Пълната конфигурация на изолираната среда, включително сценариите за изграждането ѝ, за да може всеки опит да бъде повторен. Съдържанието се попълва в **[TODO: конфигурация и сценарии за изграждане на средата за опити]**.

Приложение Г. Пълни резултати от измерванията

Необобщените стойности от всички повторения, върху които стъпват таблиците от Раздел VI. Приложението съществува, за да може всяка обобщена стойност в изложението да бъде проследена до данните, от които е получена. Съдържанието се попълва в **[TODO: пълни необобщени резултати от всички повторения]**.